F5 WAF for NGINX 솔루션

원다윗 / dw.won@ddimtech.com

DDIMTECH | Solutions Engineer

2026

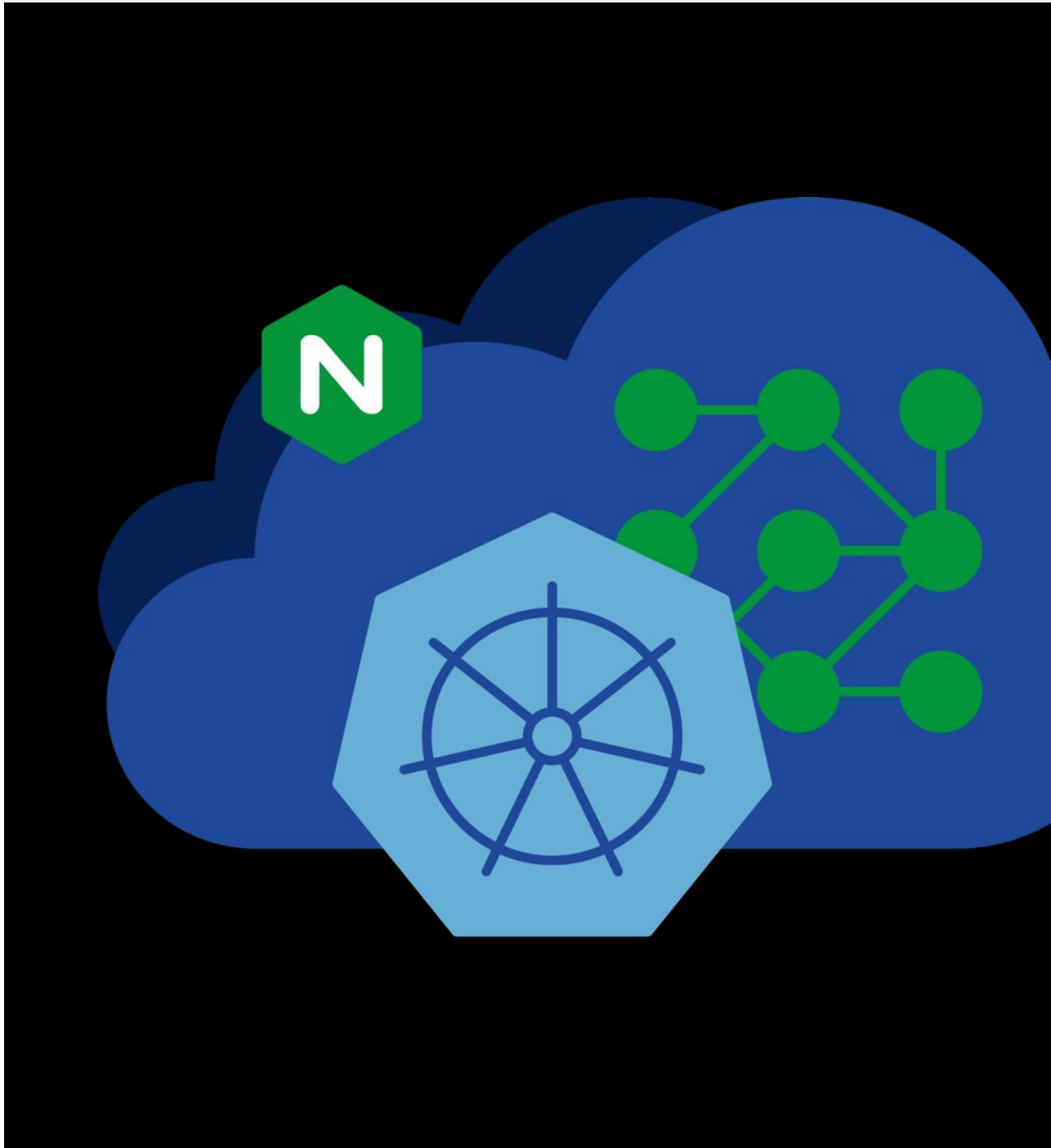
소개내용

F5 WAF for NGINX 솔루션

주요기능

정책 업데이트

정책 및 로깅 관리

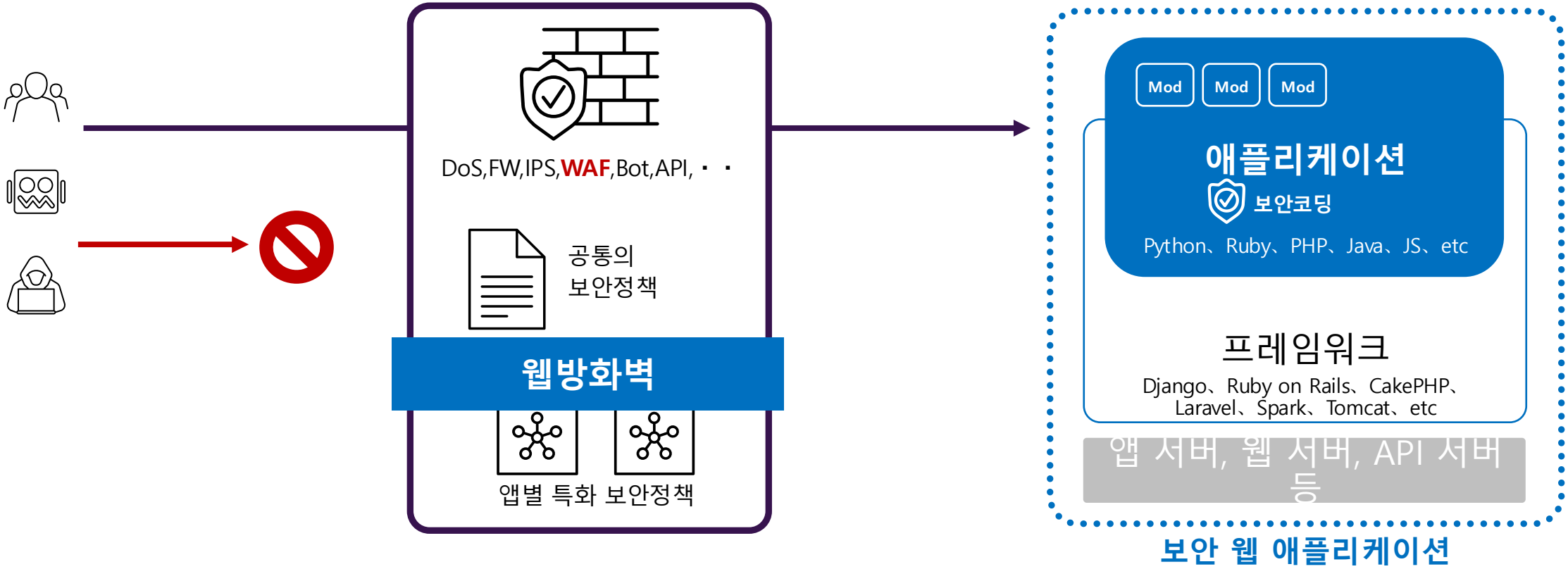


 © 2024 F5

F5 WAF for NGINX

F5 WAF for NGINX란?

모던 앱 서비스를 위한 경량화 기반 고성능의 웹방화벽



보안

고성능

Signature 외 다양한 보안기능 제공

글로벌 검증된 Signature 및 기능

자동화

CI/CD 쉬운 통합

모던 인프라 환경에 적합한 설계

보안 개선을 위한 신속한 피드백 루프

관리

통합된 인프라 환경에 적합한 설계

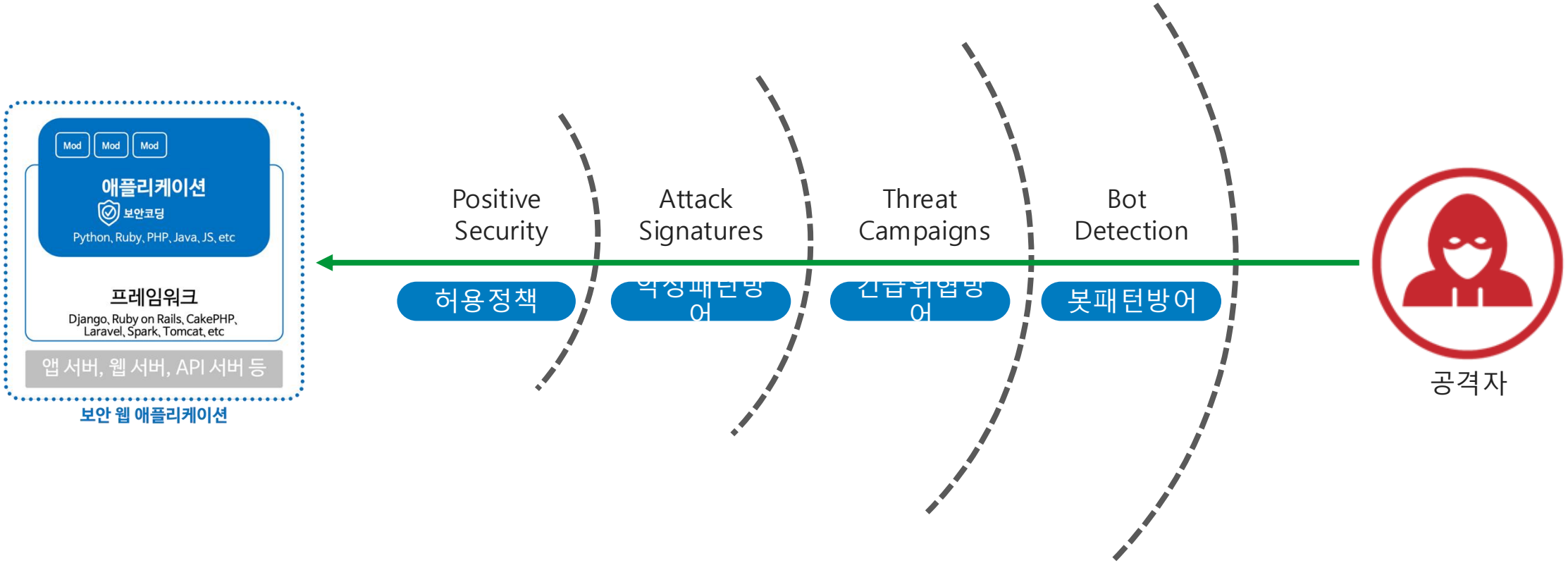
NIM 및 Syslog 기반의 보안 가시화

F5의 공식 기술지원

 © 2024 F5

F5 WAF for NGINX의 프레임워크

멀티레이어 기반의 접근방식



 © 2024 F5

봇 탐지 및 방어

자동화 기반의 공격에 대한 방어를 가장 먼저 제공

- ✓ User-Agent 해더 및 URI에서 봇 패턴 기반의 기본 봇 탐지 및 방어
- ✓ 각각의 봇 시그너처는 다음의 Bot Class 범주에 포함
  - 신뢰할 수 있는 봇(Trusted Bot)
  - 신뢰할 수 없는 봇(Untrusted Bot)
  - 악의적인 봇(Malicious Bot)

```
{
    "policy": {
        "name": "bot_defense_policy",
        "template": {
            "name": "POLICY_TEMPLATE_NGINX_BASE"
        },
        "applicationLanguage": "utf-8",
        "enforcementMode": "blocking",
        "bot-defense": {
            "settings": {
                "isEnabled": true
            },
            "mitigations": {
                "classes": [
                    {
                        "name": "trusted-bot",
                        "action": "alarm"
                    },
                    {
                        "name": "untrusted-bot",
                        "action": "block"
                    },
                    {
                        "name": "malicious-bot",
                        "action": "block"
                    }
                ]
            }
        }
    }
}
```

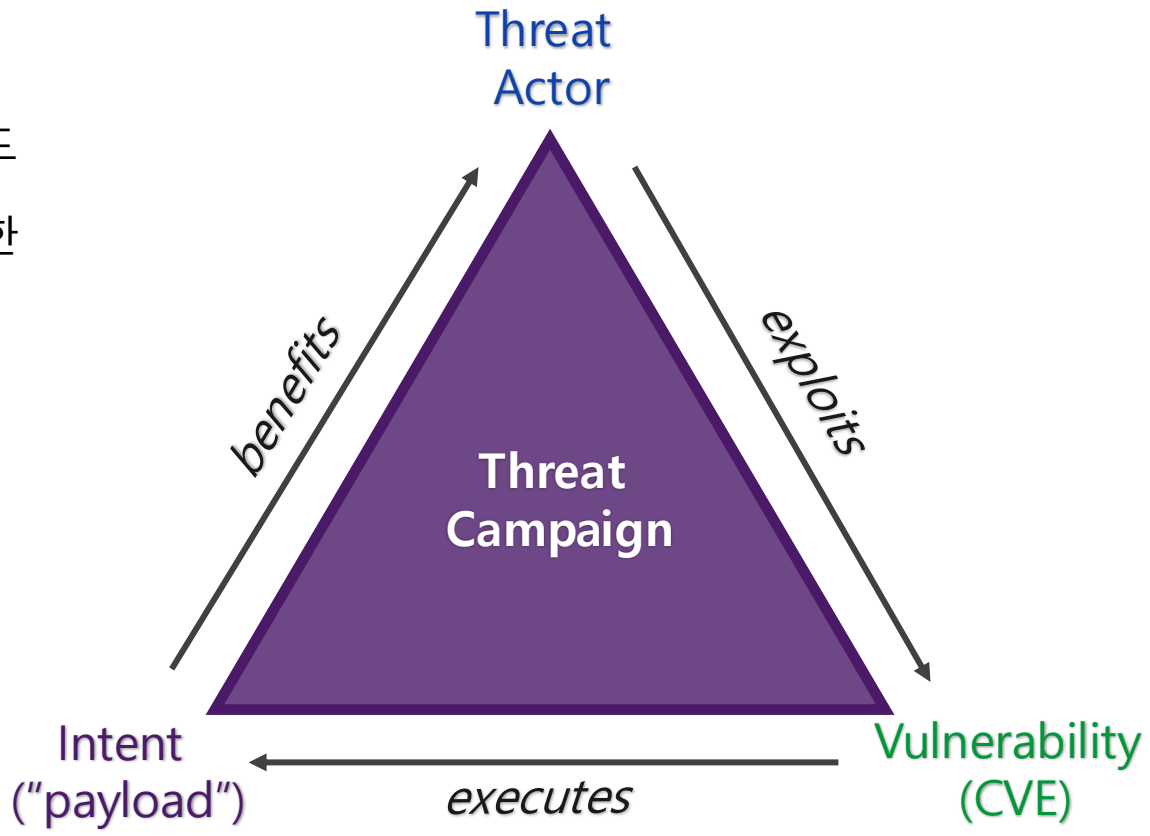
참고링크: https://docs.nginx.com/nginx-app-protect-waf/v5/configuration-guide/configuration/#anti-automation-bot-mitigation

 © 2024 F5

위협 캠페인 - Threat Campaign

현재 확인된 attack campaigns에 대한 애플리케이션 방어

- ✓ 위협 캠페인은 위협 인텔리전스 기능
- ✓ 활성 공격 캠페인에 대한 정보가 포함된 빈번한 업데이트 피드
- ✓ 위협 캠페인의 컨텍스트 정보는 현재 확인된 공격/위협에 대한 특화됨
- ✓ False Positive 없음



예시 :
APT12 are exploiting Apache Struts2 (CVE-2018-11776) to deploy crypto-miner

 © 2024 F5

Signatures - 업계 최대 수 및 빠른 업데이트

9000개 이상의 Signature 제공, 80개 이상의 서버기술

기본 제공되는 Signatures Sets:

- All Response Signatures
- All Signatures
- Generic Detection Signatures
- Generic Detection Signatures(High Accuracy)
- Generic Detection Signatures(High/Mid Accuracy)
- High Accuracy Signatures
- Low Accuracy Signatures
- Medium Accuracy Signatures
- OWA Signatures
- WebSphere Signatures

또는 80개 이상의 서버 기술로 앱 보호 정책을 사용자 정의로 사용:

Sharepoint, Python, Vue.JS, GraphQL, NodeJS, Angular, React, Express.JS,

Wordpress, Linux, XML, PHP, Windows … 등

 © 2024 F5

기본정책

일관된 기본 정책을 제공

Negative Model

- OWASP Top 10 기반의 시그너처 & CVEs
- 회피기술(Evasion Techniques)

Positive Model

- Meta Characters 확인
- HTTP Protocol Compliance
- Disallow file type(bin, cgi, cmd, dll, exe, msi, sys 등)
- Cookie Integrity Check
- JSON & XML Check
- Sensitive parameters & Data Guard

 © 2024 F5

False Positive 관리

False Positive의 관리에 도움

- ✓ 각각의 요청별 Violation Rating을 제공하여 관리자가 False Positive를 쉽게 관리할 수 있도록 지원
- ✓ Attack Signatures False Positive Mode(기본설정) 사용을 통해 Violation Rating 점수 기반의 차단을 제공

method	uri	violations	violation_rating	request_status
GET	/login.php	HTTP protocol compliance failed	3	alerted
GET	/manager/html	HTTP protocol compliance failed, Bot Client Detected	3	alerted
GET	/wp-login.php	HTTP protocol compliance failed, Bot Client Detected	3	alerted
POST	/_ignition/execute-solution	HTTP protocol compliance failed, Illegal meta character in value	2	alerted
POST	/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php	HTTP protocol compliance failed, Illegal meta character in value, Illegal meta character in parameter name, Attack signature detected, Violation Rating Threat detected	4	blocked
GET	/	HTTP protocol compliance failed	3	alerted

0	No Violation
1	False Positive
2	False Positive
3	Needs Examination
4	Threat
5	Threat

 © 2024 F5

보안가시성

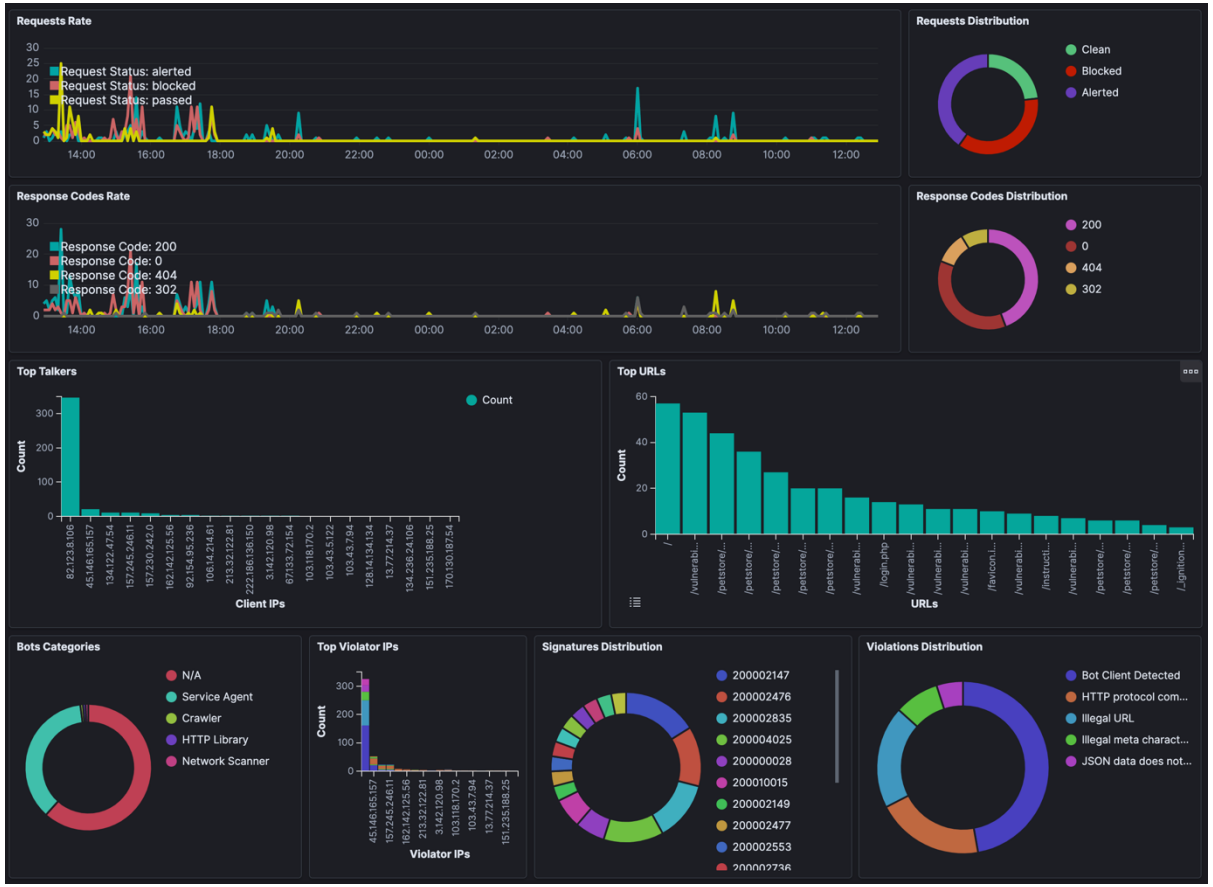
트래픽, 위반 및 차단에 대한 통합 가시성 제공

Security Log는 아래의 정보를 포함:

- **HTTP request/response**에 대한 상세정보
- NGINX App Protect의 트래픽 처리 상태
- 설정된 정책 파라메터 기반의 차단 내용
- 그리고 관련 로그 정보의 추출
  - Stderr, Files, Syslog

```
app_protect_security_log "/etc/app_protect/conf/log_default.json" syslog:server=localhost:5144;
app_protect_security_log "/etc/app_protect/conf/log_default.json" /var/log/app_protect/security.log;
app_protect_security_log "/etc/app_protect/conf/log_default.json" stderr;
```

ELK Dashboard 제공:
https://github.com/f5devcentral/f5-waf-elk-dashboards



 © 2024 F5

NIM - Policy 관리

NIM의 GUI 기반 NGINX WAF Policy 관리

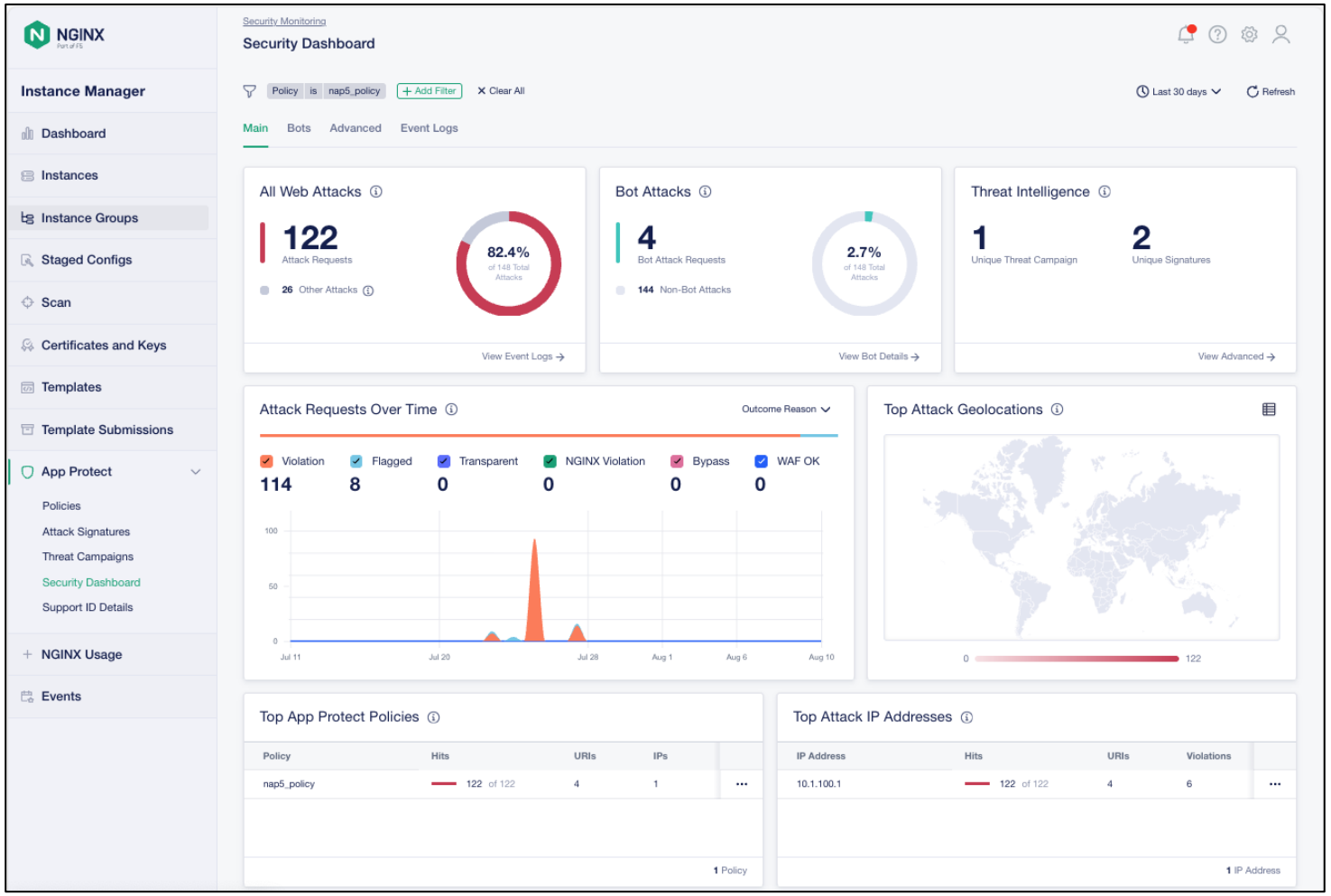
- API, GUI를 활용하여 SecOps, DevOps, Platform 팀이 NGINX WAF 통해 중앙관리 가능
  (생성/편집/배포 수행)
- 단일/다수의 NGINX WAF 인스턴스에 WAF 보안정책 업데이트를 대규모 배포/추적 가능
- Control Plane(NIM)에서 정책 컴파일을 수행하여 Data plane(NGINX Plus/NGINX OSS)의 성능을 향상
- 다수의 NGINX WAF 인스턴스의 보안 이벤트를 중앙관리 및 모니터링
- 버전 관리 기능을 통해 손쉽게 롤백/변경 이력 추적 가능
- UI 기반 정책 관리 및 적용

 © 2024 F5

NIM – 보안이벤트 통합 모니터링

전체 NGINX WAF에 대한 중앙집중화된 WAF 이벤트 모니터링

- SecOps팀 및 WAF팀을 위한 모니터링 도구
- 정책 튜닝 통찰력을 위해 앱별 또는 앱 전반에 걸쳐 NGINX WAF의 중앙 집중식 가시성 제공
- 자세한 분석을 위해 이벤트 로그를 사용자 지정 필터링하는 기능을 통해 주요 위반 및 위협에 대한 선별된 인사이트
- 잠재적인 봇 관련 위협에 대한 인사이트
- 차단 요청 식별자(ID)를 통해 정책을 트리거하는 요청에 대한 세부 정보제공
- Top violation에 대한 인사이트 제공



 © 2024 F5

Lab 환경 실습하기